Monitoring and Incident Response

Monitoring and Incident Response

- Monitoring Security Alerts and Events
- Incident Response Procedures:
  - Triage,
  - Containment,
  - Eradication, and
  - Recovery

Labs

- Simulated Incident Response Scenarios

Monitoring and Incident Response

- Monitoring and Incident Response in Microsoft EDR is centered around **continuous telemetry collection, behavioral analytics, automated investigation, and coordinated remediation.**
- Monitoring in Defender for Endpoint operates on three core layers:
  - Telemetry Collection (Endpoint Sensors)
  - Detection Engine
  - Alert & Incident Correlation

Monitoring in Microsoft EDR – Telemetry Collection

- The Defender sensor on Windows, Linux, macOS continuously collects:
  - Process creation events
  - File creation/modification
  - Registry changes
  - Network connections
  - Logon activity
  - PowerShell activity
  - Kernel-level signals
    - This telemetry is sent to the Microsoft security cloud for correlation.

Monitoring in Microsoft EDR – Telemetry Collection

- Data Sources
  - Microsoft Defender Antivirus
  - Windows Security Logs
  - Advanced Audit Policies
  - AMSI (Anti-Malware Scan Interface)
  - ETW (Event Tracing for Windows)

Monitoring in Microsoft EDR – Detection Engine

- Microsoft uses:
  - Behavioural analytics
  - Machine learning models
  - Threat intelligence feeds
  - MITRE ATT&CK mapping

- Detections are categorized as:
  - Malware
  - Ransomware
  - Credential theft
  - Lateral movement
  - Living-off-the-land activity
  - Exploit attempts

- Each detection generates an Alert.

Monitoring in Microsoft EDR – Alert & Incident Correlation

- Individual alerts are automatically grouped into Incidents based on:
  - Device
  - User
  - Attack chain stage
  - Threat actor patterns
- This reduces alert fatigue and provides contextual attack storyline.

Incident Response Workflow in EDR
Step 1: Alert Triage

Security analyst reviews:

- Alert severity (Low, Medium, High, Critical)
- Impacted device
- Impacted user
- Detection source
- MITRE technique
- Evidence timeline

Incident Response Workflow in EDR
Step 2: Investigation

- Use – Device Timeline:
  - Full forensic sequence of:
    - Process tree
    - Network calls
    - File writes
    - Persistence mechanisms
- Use – Advance Hunting (KQL):

```
DeviceProcessEvents
| where ProcessCommandLine contains "EncodedCommand"
```

Incident Response Workflow in EDR
Step 2: Investigation

- Use – Live Response:
- Remote shell into endpoint to:
  - Collect files
  - Kill processes
  - Dump memory
  - Run scripts

Incident Response Workflow in EDR
Step 3: Automated Investigation & Remediation (AIR)

- Microsoft Defender uses automated playbooks to:
  - Analyze suspicious files
  - Check prevalence
  - Validate persistence
  - Quarantine files
  - Stop processes
  - Remove registry entries
- AIR reduces manual SOC workload.

Incident Response Workflow in EDR
Step 4: Containment

- You can:
  - Isolate device from network (full isolation)
  - Restrict app execution
  - Disable user account
  - Block hash
  - Block IP/domain
  - Trigger antivirus scan
- Device isolation is commonly used in ransomware cases.

Incident Response Workflow in EDR
Step 5: Eradication

- Remove malware
- Remove persistence mechanisms
- Patch vulnerabilities
- Reset credentials
- Reimage device if necessary

Incident Response Workflow in EDR

Step 6: Recovery

- Reconnect isolated device
- Validate clean state
- Monitor for reinfection
- Close incident

Monitoring Capabilities

- **Real-Time Monitoring**
  - Immediate detection alerts
  - Live device status
  - Active threat dashboard
- **Continuous Threat Hunting**
  - Proactive investigation even without alerts.
- **Exposure & Vulnerability Monitoring**
  - Integrated with Threat & Vulnerability Management (TVM).
- **Attack Surface Reduction Monitoring**
  - Tracks ASR rule blocks and bypass attempts.

Incident Response Roles

Role	Responsibility
Tier 1 Analyst	Triage alerts
Tier 2 Analyst	Deep investigation
Tier 3 / IR Team	Containment & eradication
Threat Hunter	Proactive hunt
SOC Manager	Oversight & reporting

Monitoring Security Alerts and Events

- Monitoring in Microsoft EDR is not just **alert viewing**, but it is a structured SOC workflow involving alert **ingestion, correlation, enrichment, prioritization, investigation, and response.**

- **Security Event**

  Raw telemetry generated by the endpoint sensor:

  - Process creation
  - File modification
  - Registry change
  - Network connection
  - Logon attempt
  - PowerShell execution

  - These are stored in advanced hunting tables.

Monitoring Security Alerts and Events

- **Security Alert**
  - A detection triggered after analytics correlate **suspicious events**.
  - Alerts include:
    - Severity (Low / Medium / High / Critical)
    - Category (Execution, Persistence, Lateral Movement, etc.)
    - MITRE ATT&CK technique mapping
    - Impacted device
    - Impacted user
    - Evidence artifacts

Alert Monitoring Workflow

- **Step 1: Access the Incident Queue**
  - Navigate → Incidents & Alerts → Incidents
  - Key fields to monitor:
    - Severity
    - Status (Active / In Progress / Resolved)
    - Assigned analyst
    - Impacted assets
    - Detection source

- **Step 2: Alert Triage Checklist**
  - When opening an alert:
  - Validate:
    - Is the device corporate managed?
    - Is the user privileged?
    - Is the process signed?
    - Is the hash known malicious?
    - Is the behavior common in environment?
  - Evaluate:
    - Prevalence in tenant
    - Global prevalence
    - First seen timestamp
    - Parent process chain
    - Network indicators

Monitoring Using Device Timeline

- Go to → Devices → Select Device → Timeline
- Analyze:
  - Process tree
  - Command line arguments
  - Lateral movement indicators
  - Persistence artifacts
  - Suspicious PowerShell activity
  - Encoded commands
  - LOLBins usage (e.g., rundll32, wmic, mshta)
- Timeline view gives full attack chain visualization.

Advanced Hunting for Event Monitoring - KQL

- **Example 1: Detect Encoded PowerShell**

```
DeviceProcessEvents
| where ProcessCommandLine contains "EncodedCommand"
| project Timestamp, DeviceName, AccountName, ProcessCommandLine
```

- **Example 2: Suspicious RDP Logons**

```
DeviceLogonEvents
| where LogonType == "RemoteInteractive"
| summarize count() by DeviceName, AccountName
```

Common Operational Mistakes

- Ignoring Low severity alerts (attackers' chain low alerts)
- Not reviewing device timeline
- Overusing alert suppression
- Not validating parent-child process chain
- Not correlating identity signals

Monitoring Security Alerts and Events

- Monitoring security alerts and events is a core SOC function that ensures early detection, accurate investigation, and timely response to malicious or suspicious activity.
- In Microsoft Defender for Endpoint (MDE), alerts and events are generated from continuous endpoint telemetry and correlated into incidents.

Security Events

- Raw telemetry collected from endpoints
- Examples:
  - Process execution
  - Registry modification
  - Network connection
  - Logon activity
- High volume, low context

Security Alerts

- High-confidence detections generated from events
- Represent suspicious or malicious behavior
- Mapped to **MITRE ATT&CK**
- Actionable and prioritized

Monitoring Workflow in MDE

Step 1: Alert Triage

- Review alert severity (Low, Medium, High)
- Validate detection confidence
- Identify impacted devices and users

Step 2: Incident Investigation

- Analyze attack timeline
- Review process trees
- Examine file hashes and network connections
- Identify root cause

Step 3: Event Deep Dive

- Drill down into raw events:
  - Process events
  - File events
  - Registry events
  - Network events
- Use advanced hunting if required

Step 4: Response & Containment

- Isolate affected devices
- Kill malicious processes
- Block indicators (hash, IP, domain)
- Trigger automated remediation

Step 5: Post-Incident Review

- Tune detection rules
- Update ASR policies
- Document lessons learned

Tools Used for Monitoring

Microsoft Defender Portal	Advanced Hunting (KQL)	Microsoft Sentinel (Optional)
• Central dashboard • Incident queue • Alert timelines • Device inventory	• Query raw events • Correlate activity across devices • Proactively hunt for threats	• Centralized SIEM • Cross-domain correlation • Long-term log retention

That's all Folks!